

The Essential Cybersecurity Controls (ECC)

Details of the Essential Cybersecurity Controls (ECC)

1 cybersecurity Governance

1-1	Cybersecurity Strategy
Objective	To ensure that the action plans, objectives, initiatives, and projects of the entity contribute to compliance with the relevant legislative and regulatory requirements.
Controls	
1-1-1	The cybersecurity strategy of the entity shall be identified, documented, and approved, and it shall be supported by the head of the entity or his/her delegate (Hereinafter referred to as the “Authorized Official”). The strategy goals shall be in line with the relevant legislative and regulatory requirements.
1-1-2	The entity shall execute an action plan to apply the cybersecurity strategy.
1-1-3	The cybersecurity strategy shall be reviewed at planned intervals (or in case of changes to the relevant legislative and regulatory requirements).
1-2	Cybersecurity Management
Objective	To ensure that the Authorized Official of the entity complies with and supports the implementation and management of cybersecurity programs within the entity, as per the relevant legislative and regulatory requirements.
Controls	
1-2-1	A department for cybersecurity shall be established within the entity. This department shall be independent from the Information Technology and Communications Department (As per High Order No. 37140, dated 14/08/1438H.). It is recommended that the Cybersecurity Department reports directly to the head of the entity or his/her delegate while ensuring that this does not result in a conflict of interests.
1-2-2	All cybersecurity positions shall be filled out with full-time and qualified Saudi cybersecurity professionals.
1-2-3	A cybersecurity supervisory committee shall be established pursuant to the instruction of the entity’s Authorized Official to ensure compliance with, support for, and monitoring of the implementation of the cybersecurity programs and regulations. The committee’s members, responsibilities, and governance framework shall be identified, documented, and approved. The committee shall include the head of the cybersecurity

	department as a member. It is recommended that the committee reports directly to the head of the entity or his/her delegate while ensuring that this does not result in a conflict of interests.
1-3	Cybersecurity Policies and Procedures
Objective	To ensure that the cybersecurity requirements and the entity's compliance therewith are documented and communicated, as per the entity's regulatory requirements and the relevant legislative and regulatory requirements.
Controls	
1-3-1	The cybersecurity department of the entity shall identify and document cybersecurity policies and procedures, including the cybersecurity controls and requirements, and have them approved by the entity's Authorized Official, and communicate them to the relevant personnel and parties inside the entity.
1-3-2	The cybersecurity department shall ensure that the cybersecurity policies and procedures, including the relevant controls and requirements, are implemented at the entity.
1-3-3	The cybersecurity policies and procedures shall be supported by technical security standards (e.g. technical security standards for firewall, databases, operating systems, etc.).
1-3-4	The cybersecurity policies and procedures shall be reviewed and updated at planned intervals (or in case of changes to the relevant legislative and regulatory requirements and standards). Changes shall be documented and approved.
1-4	Cybersecurity Roles and Responsibilities
Objective	To ensure that roles and responsibilities are clearly defined for all parties participating in implementing the cybersecurity controls within the entity.
Controls	
1-4-1	The Authorized Official shall identify, document, and approve the governance organizational structure, roles, and responsibilities of the entity's cybersecurity, and assign the persons concerned therewith. The necessary support shall be provided for the implementation thereof while ensuring that this does not result in a conflict of interests.
1-4-2	The cybersecurity roles and responsibilities within the entity shall be reviewed and updated at planned intervals (or in case of changes to the relevant legislative and regulatory requirements).

1-5	Cybersecurity Risk Management
Objective	To ensure managing cybersecurity risks in a methodological approach, in order to protect the entity's information and technology assets, as per the entity's regulatory policies and procedures and the relevant legislative and regulatory requirements.
Controls	
1-5-1	The cybersecurity department of the entity shall identify, document, and approve the cybersecurity risk management methodology and procedures within the entity, in accordance with considerations of confidentiality, and the integrity and availability of information and technology assets.
1-5-2	The cybersecurity department shall implement the cybersecurity risk management methodology and procedures within the entity.
1-5-3	The cybersecurity risk assessment procedures shall be implemented at least in the following cases: 1.5.3.1 At early stage of technology projects. 1.5.3.2 Before making major changes to technology infrastructure. 1.5.3.3 During planning to obtain third party services. 1.5.3.4 During planning and before the release of new technology services and products.
1-5-4	The cybersecurity risk management methodology and procedures shall be reviewed and updated at planned intervals (or in case of changes to the relevant legislative and regulatory requirements and standards). Changes shall be documented and approved.
1-6	Cybersecurity in Information and Technology Project Management
Objective	To ensure that cybersecurity requirements are included in the methodology and procedures of the entity's project management, in order to protect the confidentiality, integrity, accuracy, and availability of the entity's information and technology assets, as per the entity's regulatory policies and procedures and the relevant legislative and regulatory requirements.
Controls	
1-6-1	Cybersecurity requirements shall be included in the project management methodology and procedures and in the information and technology asset change management within the entity to ensure identifying and managing cybersecurity risks as part of the technology project lifecycle. The cybersecurity requirements shall be a key part of the requirements for technology projects.

1-6-2	The cybersecurity requirements for project management and information and technology asset changes within the entity shall include the following as a minimum: 1.6.2.1 Vulnerability assessment and remediation. 1.6.2.2 Reviewing secure configuration and hardening and updates packages before launching projects and changes.
1-6-3	The cybersecurity requirements for software and application development projects within the entity shall include the following as a minimum: 1.6.3.1 Using the secure coding standards. 1.6.3.2 Using trusted and licensed sources for software development tools and libraries. 1.6.3.3 Conducting compliance test for software against the cybersecurity requirements within the entity. 1.6.3.4 Secure integration between applications. 1.6.3.5 Reviewing secure configuration and hardening and updates packages before launching software products
1-6-4	The cybersecurity requirements for project management within the entity shall be periodically reviewed.
1.7	Compliance with Cybersecurity Standards, Laws and Regulations
Objective	To ensure that the entity's cybersecurity program complies with the relevant legislative and regulatory requirements.
Controls	
1-7-1	If there are nationally approved international agreements or commitments that include cybersecurity requirements, the entity shall identify and comply with these requirements.
1-8	Periodical Cybersecurity Review and Audit
Objective	To ensure that the cybersecurity controls adopted by the entity are implemented and applicable in accordance with the entity's regulatory policies and procedures, relevant national legislative and regulatory requirements, and international requirements imposed on the entity by law.
Controls	
1-8-1	The cybersecurity department of the entity shall periodically review the implementation of cybersecurity controls by the entity.

1-8-2	The implementation of cybersecurity controls by the entity shall be reviewed and audited by parties other than the cybersecurity department at the entity, provided that the audit and review are to be conducted independently while considering the principle of conflict of interest, as per the Generally Accepted Auditing Standards (GAAS) and the relevant legislative and regulatory requirements.
1-8-3	The results of cybersecurity audits and reviews shall be documented and presented to the cybersecurity supervisory committee and the Authorized Official. Results shall include the audit and review scope, observations, recommendations, corrective actions, and remediation plans.
1-9	Cybersecurity in Human Resources
Objective	To ensure that cybersecurity risks and requirements for personnel (employees and contractors) of the entity are managed efficiently prior to, during, and upon the end or termination of their employment, as per the entity's regulatory policies and procedures and the relevant legislative and regulatory requirements.
Controls	
1-9-1	Cybersecurity requirements for personnel of the entity shall be identified, documented, and approved prior to, during, and upon the end or termination of their employment.
1-9-2	Cybersecurity requirements for personnel of the entity shall be implemented.
1-9-3	Cybersecurity requirements prior to the commencement of the employment relationship between personnel and the entity shall include the following as a minimum: 1.9.3.1 Incorporating the personnel's cybersecurity responsibilities clauses and non-disclosure clauses in their employment contracts with the entity (including during and after employment end/termination with the entity). 1.9.3.2 Conducting screening or vetting for personnel in cybersecurity positions and technical positions with critical and privileged powers.
1-9-4	Cybersecurity requirements for personnel during their employment relationship with the entity shall include the following as a minimum: 1.9.4.1 Cybersecurity awareness (during on-boarding and during employment). 1.9.4.2 Implementation and compliance with cybersecurity requirements, as per the entity's cybersecurity policies, procedures, and operations.
1-9-5	The personnel's powers shall be reviewed and revoked immediately upon the end/termination of their employment with the entity.
1-9-6	Cybersecurity requirements for personnel of the entity shall be periodically reviewed.

1-10	Cybersecurity Awareness and Training Program
Objective	To ensure that the entity's personnel have the required security awareness, are aware of their cybersecurity responsibilities, and are equipped with the required cybersecurity skills, qualifications, and training courses in order to protect the entity's information and technology assets and fulfill their cybersecurity duties.
Controls	
1-10-1	A cybersecurity awareness program , delivered through multiple channels, shall be periodically developed and approved by the entity to strengthen the awareness about cybersecurity, cyber threats, and risks, and to build a positive cybersecurity awareness culture.
1-10-2	The approved cybersecurity awareness program shall be implemented within the entity.
1-10-3	The cybersecurity awareness program shall include how to protect the entity against the most important and latest cyber risks and threats, including: 1.10.3.1 Secure handling of email services , especially phishing emails. 1.10.3.2 Secure handling of mobile devices and storage media. 1.10.3.3 Secure Internet browsing. 1.10.3.4 Secure usage of social media .
1-10-4	Specialized skills and necessary training shall be provided to personnel in positions that are linked directly to cybersecurity within the entity. Such skills and training shall be classified in line with their cybersecurity responsibilities, including: 1.10.4.1 Cybersecurity department personnel. 1.10.4.2 Personnel working on software/application development and those working on information and technology assets of the entity. 1.10.4.3 Executive and supervisory positions.
1-10-5	The implementation of cybersecurity awareness program within the entity shall be periodically reviewed .



Cybersecurity Defense

2-1	Asset Management
Objective	To ensure that the entity has an accurate and updated inventory of assets, including details of all information and technology assets of the entity, in order to support the entity's operations and cybersecurity requirements to maintain the confidentiality, integrity, accuracy, and availability of information and technology assets of the entity.
Controls	
2-1-1	Cybersecurity requirements for managing information and technology assets of the entity shall be identified, documented, and approved.
2-1-2	Cybersecurity requirements for managing information and technology assets of the entity shall be implemented.
2-1-3	The policy of acceptable use of information and technology assets of the entity shall be identified, documented, approved, and communicated.
2-1-4	The policy of acceptable use of information and technology assets of the entity shall be implemented.
2-1-5	Information and technology assets of the entity shall be classified, labeled, and handled as per the relevant legislative and regulatory requirements.
2-1-6	Cybersecurity requirements for managing information and technology assets of the entity shall be periodically reviewed.
2-2	Identity and Access Management
Objective	To ensure protecting cybersecurity of logical access to information and technology assets of the entity, in order to prevent unauthorized access and restrict access to the extent necessary for accomplishment of the assigned tasks of the entity.
Controls	
2-2-1	Cybersecurity requirements for identity and access management of the entity shall be identified, documented, and approved.
2-2-2	Cybersecurity requirements for identity and access management of the entity shall be implemented.
2-2-3	Cybersecurity requirements for identity and access management of the entity shall include the following as a minimum: 2.2.3.1 Single-factor authentication based on username and password.

	2.2.3.2 Multi-factor authentication, and defining the suitable authentication factors and their numbers as well as the suitable authentication techniques based on the result of impact assessment of authentication failure and bypass for remote access and for privileged accounts. 2.2.3.3 User authorization based on identity and access control principles (Need-to-Know and Need-to-Use principle, Least Privilege principle, and Segregation of Duties principle). 2.2.3.4 Privileged access management. 2.2.3.5 Periodic review of identities and access rights.
2-2-4	The implementation of cybersecurity requirements for identity and access management of the entity shall be periodically reviewed.
2-3	Information System and Processing Facilities Protection
Objective	To ensure the protection of information systems and processing facilities, including workstations and infrastructures of the entity, against cyber risks.
Controls	
2-3-1	Cybersecurity requirements for protection of information system and processing facilities of the entity shall be identified, documented, and approved.
2-3-2	Cybersecurity requirements for protection of information systems and processing facilities of the entity shall be implemented.
2-3-3	Cybersecurity requirements for protection of information systems and processing facilities of the entity shall include the following as a minimum: 2.3.3.1 Protection from viruses, suspicious programs and activities, and malware on workstations and servers, using modern and advanced protection technologies and mechanisms, and securely managing them. 2.3.3.2 Strict restriction on the use of external storage media and their security. 2.3.3.3 Patch management for systems, applications, and devices. 2.3.3.4 Centralized clock synchronization with an accurate and trusted source, such as sources provided by the Saudi Standards, Metrology and Quality Organization (SASO).
2-3-4	The implementation of cybersecurity requirements for protection of the information system and processing facilities of the entity shall be periodically reviewed.

2-4	Email Protection
Objective	To ensure the protection of the entity's email service against cyber risks.
Controls	
2-4-1	Cybersecurity requirements for protection of the email service of the entity shall be identified, documented, and approved.
2-4-2	Cybersecurity requirements for protection of email service of the entity shall be implemented.
2-4-3	Cybersecurity requirements for protection of the email service of the entity shall include the following as a minimum: 2.4.3.1 Analyzing and filtering email messages (specifically phishing emails and spam emails) using modern and advanced email protection techniques and mechanisms. 2.4.3.2 Multi-factor authentication, and defining the suitable authentication factors and their numbers as well as the suitable authentication techniques based on the result of impact assessment of authentication failure and bypass for remote and webmail access. 2.4.3.3 Email archiving and backup. 2.4.3.4 Secure management and protection against Advanced Persistent Threats (APT), which normally utilize zero-day malware and viruses. 2.4.3.5 Validation of the entity's email service domains by using Sender Policy Framework (SPF), Domain Keys Identified Mail (DKIM), and Domain Message Authentication Reporting and Conformance (DMARC).
2-4-4	The implementation of cybersecurity requirements for email service of the entity shall be periodically reviewed.
2-5	Networks Security Management
Objective	To ensure the protection of entity's networks against cyber risks.
Controls	
2-5-1	Cybersecurity requirements for the entity's network security management shall be identified, documented, and approved.
2-5-2	Cybersecurity requirements for the entity's network security management shall be implemented.
2-5-3	Cybersecurity requirements for the entity's network security management shall include the following as a minimum:

	2.5.3.1 Logical or physical isolation and segmentation of network segments in a secure manner which is required to control relevant cybersecurity risks, using firewall and defense-in-depth principle. 2.5.3.2 Isolation of production network from testing and development environment networks. 2.5.3.3 Secure browsing and internet connectivity, including strict restrictions on suspicious websites, file storage/sharing websites, and remote access websites. 2.5.3.4 Wireless network security and protection using secure authentication and encryption techniques and avoiding the connection of wireless networks to the entity's internal network, except after a comprehensive assessment of subsequent risks, with handling them in a way that protects the technology assets of the entity. 2.5.3.5 Restricting and managing network services, protocols, and ports. 2.5.3.6 Intrusion Prevention Systems (IPS). 2.5.3.7 Security of Domain Name Service (DNS). 2.5.3.8 Secure management and protection of Internet browsing channel against Advanced Persistent Threats (APT), which normally utilize zero-day malware and viruses. 2-5-3-9 Protecting against Distributed Denial of Service (DDoS) attacks to limit risks arising from these attacks.
2-5-4	The implementation of cybersecurity requirements for the entity's network security management shall be periodically reviewed.
2-6	Mobile Devices Security
Objective	To ensure the protection of the entity's mobile devices (including laptops, smartphones, and tablets) against cyber risks, and ensure secure handling of the entity's sensitive information and business information and protecting them during transfer and storage while using the devices of personnel of the entity (Bring Your Own Device "BYOD" policy).
Controls	
2-6-1	Cybersecurity requirements for mobile devices and BYOD security when connected to the entity's network shall be identified, documented, and approved.
2-6-2	Cybersecurity requirements for mobile devices and BYOD security of the entity shall be implemented.
2-6-3	Cybersecurity requirements for mobile devices and BYOD security of the entity shall include the following as a minimum:

	2.6.3.1 Separation and encryption of the entity's data and information stored on mobile devices and BYODs. 2.6.3.2 Controlled and restricted use based on the requirements of the interest of the entity's business. 2.6.3.3 Deletion of the entity's data and information stored on mobile devices and BYOD in cases of device loss or after the ending/termination of employment with the entity. 2.6.3.4 Security awareness for users.
2-6-4	The implementation of cybersecurity requirements for mobile devices and BYOD security of the entity shall be periodically reviewed.
2-7	Data and Information Protection
Objective	To ensure confidentiality, integrity, accuracy, and availability of the entity's data and information, as per the entity's regulatory policies and procedures and the relevant legislative and regulatory requirements
Controls	
2-7-1	Cybersecurity requirements for protecting and handling data and information of the entity shall be identified, documented, and approved, as per the relevant legislative and regulatory requirements.
2-7-2	Cybersecurity requirements for protecting data and information of the entity shall be implemented, based on its classification level.
2-7-3	The implementation of cybersecurity requirements for protecting data and information of the entity shall be periodically reviewed.
2-8	Cryptography
Objective	To ensure the proper and efficient use of cryptography to protect electronic information assets of the entity, as per the entity's regulatory policies and procedures and the relevant legislative and regulatory requirements.
Controls	
2-8-1	Cybersecurity requirements for cryptography within the entity shall be identified, documented, and approved.
2-8-2	Cybersecurity requirements for cryptography within the entity shall be implemented.
2-8-3	Cybersecurity requirements for cryptography shall include at least the requirements in the National Cryptographic Standards, published by NCA. The appropriate cryptographic standard level shall be implemented based on the nature and sensitivity of the data, systems, and networks to be protected as well as the entity's risk assessment,

	and as per the relevant legislative and regulatory requirements, as follows: 2.8.3.1 Approved cryptographic systems and solutions standards and their technical and regulatory restrictions. 2.8.3.2 Secure management of cryptographic keys during their lifecycles. 2.8.3.3 Encryption of data in-transit and at-rest, as per their classification and the relevant legislative and regulatory requirements.
2-8-4	The implementation of cybersecurity requirements for cryptography within the entity shall be periodically reviewed .
2-9	Backup and Recovery Management
Objective	To ensure the protection of the entity's data, information, and technical configurations of systems and applications against cyber risks, as per the entity's regulatory policies and procedures and the relevant legislative and regulatory requirements.
Controls	
2-9-1	Cybersecurity requirements for backup and recovery management within the entity shall be identified, documented, and approved.
2-9-2	Cybersecurity requirements for backup and recovery management within the entity shall be implemented .
2-9-3	Cybersecurity requirements for backup and recovery management shall include the following as a minimum: 2.9.3.1 Scope of backups to cover critical technology and information assets. 2.9.3.2 Ability to perform quick recovery of data and systems after cybersecurity incidents. 2.9.3.3 Periodic testing for the effectiveness of backup recovery.
2-9-4	The implementation of cybersecurity requirements for backup and recovery management within the entity shall be periodically reviewed .
2-10	Vulnerabilities Management
Objective	To ensure timely detection and effective remediation of technical vulnerabilities to prevent or minimize the probability of exploitation of these vulnerabilities by cyber-attacks and to reduce any impacts on the entity's business.
Controls	
2-10-1	Cybersecurity requirements for technical vulnerabilities management within the entity shall be identified, documented, and approved.
2-10-2	Cybersecurity requirements for technical vulnerabilities management within the entity shall be implemented .

2-10-3	Cybersecurity requirements for technical vulnerabilities management shall include the following as a minimum: 2.10.3.1 Periodic vulnerabilities assessment and detection. 2.10.3.2 Vulnerabilities classification based on their severities. 2.10.3.3 Vulnerabilities remediation based on their classification and the associated cyber risks. 2.10.3.4 Patch management to remediate vulnerabilities, and ensuring the integrity and effectiveness of these updates and fixes are verified using a non-production environment before being applied. 2.10.3.5 Communication and subscription with trusted resources for new and up-to-date vulnerabilities.
2-10-4	The implementation of cybersecurity requirements for technical vulnerabilities management within the entity shall be periodically reviewed .
2-11	Penetration Testing
Objective	To assess and test the efficiency of the entity's cybersecurity defense capabilities through simulation of actual cyber-attack methods and technologies to discover unknown weaknesses that may lead to cyber penetration of the entity, as per the relevant legislative and regulatory requirements.
Controls	
2-11-1	Cybersecurity requirements for penetration testing within the entity shall be identified, documented, and approved.
2-11-2	Cybersecurity requirements for penetration testing within the entity shall be implemented .
2-11-3	Cybersecurity requirements for penetration testing shall include the following as a minimum: 2.11.3.1 Scope of penetration testing to include all externally provided services (via the Internet) and their technical components, including infrastructure, websites, web applications, smartphone and tablet applications, email, and remote access. 2.11.3.2 Conducting penetration tests periodically.
2-11-4	The implementation of cybersecurity requirements for penetration testing shall be periodically reviewed .

2-12	Cybersecurity Event Logs and Monitoring Management
Objective	To ensure timely collection, analysis, and monitoring of cybersecurity event logs for proactive detection and effective management of cyber-attacks to prevent or minimize negative impacts on the entity's business.
Controls	
2-12-1	Cybersecurity requirements for cybersecurity event logs and monitoring management within the entity shall be identified, documented, and approved.
2-12-2	Cybersecurity requirements for cybersecurity event logs and monitoring management within the entity shall be implemented.
2-12-3	Cybersecurity requirements for cybersecurity event logs and monitoring management shall include the following as a minimum: 2.12.3.1 Activation of cybersecurity event logs for critical information assets within the entity. 2.12.3.2 Activation of cybersecurity event logs for critical and privileged accounts accessing information assets as well as for remote access events within the entity. 2.12.3.3 Identification of Security Information and Event Management (SIEM) techniques required for cybersecurity event logs collection. 2.12.3.4 Continuous monitoring of cybersecurity event logs. 2.12.3.5 Retention period of cybersecurity event logs (shall be at least 12 months).
2-12-4	The implementation of cybersecurity requirements for cybersecurity event logs and monitoring management within the entity shall be periodically reviewed.
2-13	Cybersecurity Incident and Threat Management
Objective	To ensure timely identification, detection, and effective management of cybersecurity incidents and proactive response to cybersecurity threats to prevent or minimize impacts on the entity's business, as per High Order No. 37140, dated 14/08/1438H.
Controls	
2-13-1	Requirements for cybersecurity incident and threat management within the entity shall be identified, documented, and approved.
2-13-2	Requirements for cybersecurity incident and threat management within the entity shall be implemented.

2-13-3	Requirements for cybersecurity incident and threat management shall include the following as a minimum: 2.13.3.1 Cybersecurity incident response plans and escalation procedures. 2.13.3.2 Cybersecurity incident classification. 2.13.3.3 Reporting cybersecurity incidents to the NCA. 2.13.3.4 Sharing cybersecurity incident notifications, threat intelligence, penetration indicators, and incident reports with the NCA. 2.13.3.5 Collecting and handling threat intelligence feeds.
2-13-4	The implementation of cybersecurity requirements for incident and threat management within the entity shall be periodically reviewed.
2-14	Physical Security
Objective	To ensure the protection of information and technology assets of the entity against unauthorized physical access, loss, theft, and damage.
Controls	
2-14-1	Cybersecurity requirements for protection of information and technology assets of the entity against unauthorized physical access, loss, theft, and damage shall be identified, documented, and approved.
2-14-2	Cybersecurity requirements for protection of information and technology assets of the entity against unauthorized physical access, loss, theft, and damage shall be implemented.
2-14-3	Cybersecurity requirements for protection of information and technology assets of the entity against unauthorized physical access, loss, theft, and damage shall include the following as a minimum: 2.14.3.1 Authorized access to critical areas within the entity (e.g. the entity's data center, disaster recovery center, critical information processing facilities, security surveillance center, network connection rooms, technical device and equipment supply areas, etc.). 2.14.3.2 Access and monitoring logs (CCTV). 2.14.3.3 Protection of access and monitoring log information. 2.14.3.4 Security of the destruction and re-use of physical assets that hold classified information (including paper documents and storage media). 2.14.3.5 Security of devices and equipment inside and outside the entity's facilities.
2-14-4	Cybersecurity requirements for protection of information and technology assets of the entity against unauthorized physical access, loss, theft, and damage shall be periodically reviewed.

2-15	Web Application Security
Objective	To ensure the protection of external web applications of the entity against cyber risks.
Controls	
2-15-1	Cybersecurity requirements for protection of external web applications of the entity shall be identified, documented, and approved.
2-15-2	Cybersecurity requirements for protection of external web applications of the entity shall be implemented.
2-15-3	Cybersecurity requirements for protection of external web applications of the entity shall include the following as a minimum: 2.15.3.1 Use of web application firewall. 2.15.3.2 Adoption of the multi-tier architecture principle. 2.15.3.3 Use of secure protocols (e.g. HTTPS). 2.15.3.4 Clarification of the secure usage policy for users. 2.15.3.5 User authentication, and the suitable authentication factors and their numbers as well as the authentication techniques shall be defined based on the result of impact assessment of authentication failure and bypass for users' access.
2-15-4	Cybersecurity requirements for protection of web applications of the entity shall be periodically reviewed.



Cybersecurity Resilience

3-1	Cybersecurity Resilience Aspects of Business Continuity Management (BCM)
Objective	To ensure the inclusion of cybersecurity resilience requirements in the entity's business continuity management and remediate and minimize the impacts of disruptions on the entity's critical e-services and information processing systems and facilities caused by cyber risks.
Controls	
3-1-1	Cybersecurity requirements for business continuity management within the entity shall be identified, documented, and approved.
3-1-2	Cybersecurity requirements for business continuity management within the entity shall be implemented.
3-1-3	Cybersecurity requirements for business continuity management within the entity shall include the following as a minimum: 3.1.3.1 Ensuring the continuity of cybersecurity systems and procedures. 3.1.3.2 Developing plans for response to cybersecurity incidents that may affect the entity's business continuity. 3.1.3.3 Developing disaster recovery plans.
3-1-4	Cybersecurity requirements for business continuity management within the entity shall be periodically reviewed.



Third-Party and Cloud Computing Cybersecurity

4-1	Third-Party Cybersecurity
Objective	To ensure the protection of the entity's assets against third-party cybersecurity risks (including Information Technology (IT) outsourcing, cybersecurity outsourcing, and managed services), as per the entity's regulatory policies and procedures and the relevant legislative and regulatory requirements.
Controls	
4-1-1	Cybersecurity requirements for the entity's contracts and agreements with third parties shall be identified, documented, and approved.
4-1-2	Cybersecurity requirements for contracts and agreements with third parties, e.g. Service Level Agreement (SLA), which, if impaired, may affect the entity's data or services shall include the following as a minimum: 4.1.2.1 Clauses of non-disclosure and the secure removal of the entity's data by the third party upon the end of service. 4.1.2.2 Communication procedures in case of the occurrence of a cybersecurity incident. 4.1.2.3 Obligating the third party to apply the entity's cybersecurity requirements and policies and the relevant legislative and regulatory requirements.
4-1-3	Cybersecurity requirements for contracts and agreements with third parties providing IT or cybersecurity outsourcing or managed services shall include the following as a minimum: 4.1.3.1 Conducting a cybersecurity risk assessment and ensuring the availability of risk mitigation controls before signing contracts and agreements or upon making changes to the relevant legislative and regulatory requirements. 4.1.3.2 Cybersecurity managed service centers for monitoring and operations which use remote access shall be fully located in the Kingdom of Saudi Arabia.
4-1-4	Cybersecurity requirements for third parties shall be periodically reviewed.

4-2	Cloud Computing and Hosting Cybersecurity
Objective	To ensure proper and efficient remediation of cyber risks and implementation of cybersecurity requirements for cloud computing and hosting, as per the entity's regulatory policies and procedures, relevant legislative and regulatory requirements, orders, and decisions, and to ensure the protection of the entity's information and technology assets on cloud computing services hosted, processed, or managed by third parties.
Controls	
4-2-1	Cybersecurity requirements for use of cloud computing and hosting services shall be identified, documented, and approved.
4-2-2	Cybersecurity requirements for the cloud computing and hosting services within the entity shall be implemented.
4-2-3	In accordance with the relevant legislative and regulatory requirements, and in addition to the applicable controls in the Main Domains (1), (2), and (3) and Subdomain (4.1) that are necessary to protect the entity's data or services provided thereto, cybersecurity requirements for use of cloud computing and hosting services shall include the following as a minimum: 4.2.3.1 Protection of entity's data by cloud and hosting service providers in accordance with its classification level and returning data (in a usable format) upon service completion. 4.2.3.2 Separation of the entity's environment (especially virtual servers) from environments of other entities within the cloud computing service provider.
4-2-4	Cybersecurity requirements for cloud computing and hosting services shall be periodically reviewed.